

## Seguridad Aplicada

### Presentación

Se conocerán los ataques más utilizados, donde notarán tanto la facilidad de cómo lo realizan hasta los beneficios que un atacante obtiene.

Conocerán el uso recomendado de Scanner de Vulnerabilidades.

### Objetivos

Que los participantes logren...

- Conocer sobre el mundo de los servidores informáticos, existentes en toda infraestructura informática de mediana y alta gama.
- Conocer las herramientas esenciales y las buenas prácticas necesarias para obtener el máximo nivel de seguridad en una red de servidores de arquitectura Microsoft Windows Server o Linux Server, protegiéndola de potenciales amenazas.
- Comprender los conceptos básicos referentes a la implementación, configuración, mantenimiento y soporte de servidores de infraestructura en tecnologías Windows o Linux.

### Bloques temáticos

#### Potenciales Ataques

#### Escaneo de Vulnerabilidades

#### Potenciales Ataques



Empezar a explicar este tema en detalle, sería imposible realizarlo sin comprender antes, que es lo que HOY pasa y muchos profesionales o no profesionales miran para el otro lado.

¿Es normal que una empresa no declare un incidente? ¿Acaso para no implicar el nombre de la empresa en el mismo? o ¿para ocultar la ineficiencia, desliz o error involuntario?

Hora de ser responsables, aceptar el compromiso que se necesita para cuidar la información, para lograr una eficiencia adecuada, nadie pide seguridad al 100% (no existe), pero tampoco es como para dejar las llaves puestas en una puerta e irse de vacaciones.

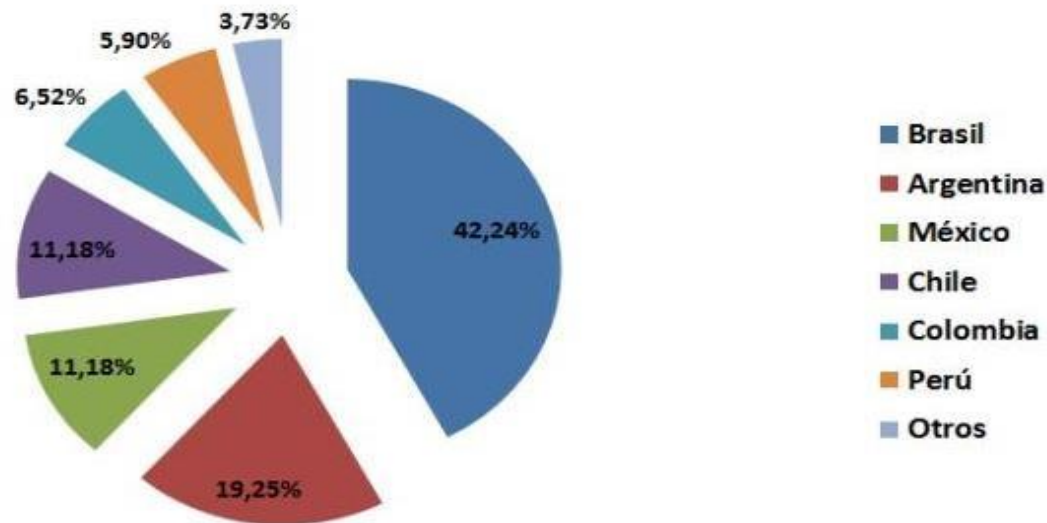
Sitios como Please to Robme, donde exponen cuando una persona, en una red social conocida, declara que se va de vacaciones, exponiendo su situación personal.

Redes sociales, donde uno es libre de publicar lo que quiera, pero es necesario, ¿publicar una imagen de la tarjeta de crédito? ¿O exponer datos personales?

Esto no se soluciona con un Firewall, Vlan o un sistema integrado de seguridad, esto ya es un tema de CONCIETIZACIÓN.

Observemos el siguiente cuadro sobre ataques en Latinoamérica

## Porcentaje de servidores vulnerados por país



•Fuente: ESETLA (2019)

A simple vista deducimos que somos el segundo país con más servidores vulnerados, la pregunta es ¿por qué?

Las empresas no se pueden dar el lujo de denunciar ataques a sus sistemas, ya que el nivel de confianza de los clientes bajaría considerablemente.

Los administradores toman conciencia respecto de la seguridad de sus sistemas y tratan de solucionar por sí mismo las deficiencias detectadas.

Por último, podemos decir que hay miles de herramientas para mitigar, y miles de tutoriales, lo cual ocasiona una saturación de información.

Cualquier usuario sin conocimientos, puede tener la posibilidad de acceder a herramientas automáticas, donde las mismas pueden desde vulnerar o afectar la integridad de un servidor, por ejemplo.

¿Qué tipos de ataques son los más utilizados hacia los servidores?

- Ingeniería Social
- Ataques de Autenticación
- Denial of Service (DoS)
- Ataques de Modificación

Observemos un breve detalle de los mismos...

Ingeniería Social



Es una técnica con la cual uno puede obtener información confidencial a través de la manipulación, el engaño y el chantaje.

Se puede llegar a obtener:

- Acceso a privilegios en sistemas
- Realizar acciones maliciosas
- Exponer al individuo u organismo comprometido
- Qué factores se tienen en cuenta:
- Curiosidad: “alguien dejó olvidado un USB”
- Cortesía: “buscan la manera de llegar a uno”
- Credulidad: “nos muestran algo real...”
- Codicia: “nos hacen millonarios”
- Inconsciencia: “no sabemos lo que hacemos”
- Timidez: “no nos animamos a preguntar”
- Apatía: “hacemos lo que queremos”

A través del Phishing.



Una de las técnicas más utilizadas para redireccionar a las víctimas a sitios maliciosos, son los hipervínculos o enlaces.

Por eso habría que prevenir el acceso a páginas web que posean amenazas capaces de infectar al usuario, evitando hacer clic en los mismos.



Los enlaces suelen estar en un mail, en una red social, en una ventana de chat.

La clave está en analizar si son ofrecidos en alguna situación sospechosa (una invitación a ver un supuesto premio en el banco personal de uno), provienen de un remitente desconocido o remiten a un sitio web poco confiable.

Algunos ítems a tener en cuenta para determinar si es un PHISHING.

- La dirección de remitente
- Nombres de dominio mal escritos
- Errores de ortografía y de gramática
- Archivos adjuntos o enlaces sospechosos
- Sensación de urgencia
- El mensaje es demasiado bueno para ser verdad

### Distintos tipos de ataques de PHISHING

En la modalidad más común, también conocido como phishing de clonado o redireccionamiento, el atacante se hace pasar por una empresa o contacto de confianza para conseguir información personal y/o credenciales de acceso.

Las dos principales formas de llevar a cabo este ataque es: a través del mismo (correo electrónico, chat, etc.) medio robar la información con el uso de técnicas propias de la ingeniería social para ganar la confianza de la víctima y obtener la información deseada.

La segunda forma se da cuando el atacante envía un link o URL maliciosa, generalmente siendo una copia exacta de la web original.

Un paso más avanzado sería introducir un iframe o addon malicioso en la página original, explotando una vulnerabilidad que el atacante haya conseguido detectar, sin necesidad de usar una URL falsa.

### Malware Based Phishing

En este tipo de phishing el atacante introduce un archivo malicioso que contenga malware, generalmente en forma de archivo adjunto, o en forma de URL de descarga directa de un sitio malicioso.

Es una técnica muy utilizada en pequeñas y medianas empresas porque el software no suele estar actualizado y presenta mayor cantidad de vulnerabilidades.

### Spear phishing

El spear phishing es un tipo de ataque muy difícil de detectar ya que el atacante realiza una investigación previa de la víctima para poder personalizar el ataque a través del uso de estos datos privados, ganando la confianza de la víctima.

Es por esto que el concepto de phishing puede estar englobado dentro de la ingeniería social, ya que se nutre permanentemente de sus técnicas para explotar las vulnerabilidades de la personalidad de cada víctima.

Las áreas más vulnerables dentro de una empresa generalmente son el departamento de RRHH por la cantidad de información personal contenida en los currículums, y el sector de Contabilidad, por su estrecha relación con las cuentas de la empresa, contratistas, reguladores y bancos.

### Smishing (SMS)

Este tipo de phishing se realiza exclusivamente a través de SMS, o en la actualidad también podría aplicarse Whatsapp.

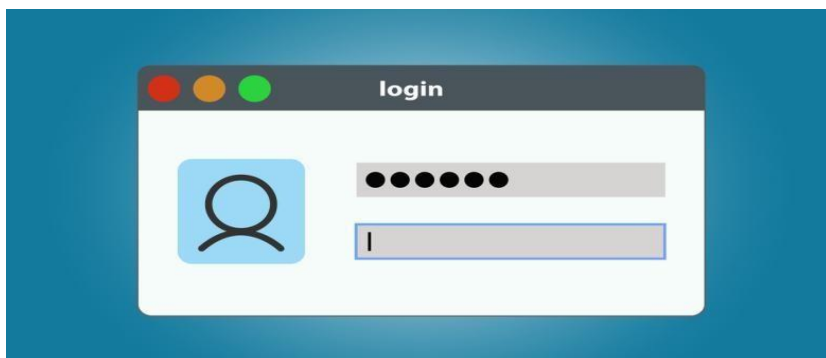
El atacante haciéndose pasar por una empresa de confianza para la víctima, le informa que ganó un premio y que debe seguir los siguientes pasos: hacer click en el URL, llamar a un número de teléfono y responder al mensaje.

### Vishing

El término proviene de “phishing de voz”, en este caso la suplantación de identidad el atacante la realiza a través del teléfono, haciéndose pasar por un empleado de una empresa con la finalidad de recabar datos personales. Suele utilizarse como

etapa previa para el spear-phishing. En Argentina es muy utilizado para desbloquear iPhones (vishing + deceptive).

### Ataques de autenticación



Son aquellos que se efectúan en sitios y accesos que requieran usuarios, passwords, etc, para poder ingresar a los mismos.

Es un tipo de ataque, que explota las debilidades de los sistemas de autenticación implementados en el objetivo (red, sistema, aplicación, página web, etc.).

La autenticación es un proceso crítico en la ciberseguridad; cuando un usuario introduce sus credenciales para autenticarse, la aplicación valida los datos ingresados, para posteriormente asignar los permisos y privilegios correspondientes a dicha identificación.

Esto dependerá de cómo el encargado de crear perfiles de usuarios determina que perfil asignarle, que a su vez, RRHH avisa o no que tipo de perfil es el usuario, y así un cuento de no acabar, por ende, se le asigna un perfil “TODO PERMITIDO”.

| Position  | Password   | Number of users |
|-----------|------------|-----------------|
| 1. ↑ (2)  | 123456     | 2,543,285       |
| 2. ↑ (3)  | 123456789  | 961,435         |
| 3. (new)  | picture1   | 371,612         |
| 4. ↑ (5)  | password   | 360,467         |
| 5. ↑ (6)  | 12345678   | 322,187         |
| 6. ↑ (17) | 111111     | 230,507         |
| 7. ↑ (18) | 123123     | 189,327         |
| 8. ↓ (1)  | 12345      | 188,268         |
| 9. ↑ (11) | 1234567890 | 171,724         |
| 10. (new) | senha      | 167,728         |

También entra en duda, si es un tema del sistema en sí o del usuario, dado que hay elementos como que una password no es robusta (el usuario utiliza algunas de las passwords más conocidas) o que el sistema pide “utilizar una contraseña de 6 caracteres numéricos” (esto le da una idea al atacante de conseguir la password correcta).

FUENTE: <https://www.zdnet.com> (2020)

Aquí tenemos un listado de las password, más utilizadas y un relevamiento de la cantidad de usuarios en un determinado servicio/aplicación, la ha utilizado.

| SplashData's worst, <b>most insecure passwords</b> of <b>2019</b> and <b>2018</b> |             |             |
|-----------------------------------------------------------------------------------|-------------|-------------|
|                                                                                   | <b>2019</b> | <b>2018</b> |
| <b>1</b>                                                                          | 123456      | 123456      |
| <b>2</b>                                                                          | 123456789   | password    |
| <b>3</b>                                                                          | qwerty      | 123456789   |
| <b>4</b>                                                                          | password    | 12345678    |
| <b>5</b>                                                                          | 1234567     | 12345       |
| <b>6</b>                                                                          | 12345678    | 111111      |
| <b>7</b>                                                                          | 12345       | 1234567     |
| <b>8</b>                                                                          | iloveyou    | sunshine    |
| <b>9</b>                                                                          | 111111      | qwerty      |
| <b>10</b>                                                                         | 123123      | iloveyou    |
| <b>11</b>                                                                         | abc123      | princess    |
| <b>12</b>                                                                         | qwerty123   | admin       |
| <b>13</b>                                                                         | 1q2w3e4r    | welcome     |
| <b>14</b>                                                                         | admin       | 666666      |
| <b>15</b>                                                                         | qwertyuiop  | abc123      |
| <b>16</b>                                                                         | 654321      | football    |
| <b>17</b>                                                                         | 555555      | 123123      |
| <b>18</b>                                                                         | lovely      | monkey      |
| <b>19</b>                                                                         | 777777      | 654321      |
| <b>20</b>                                                                         | welcome     | !@#\$%^&*   |
| <b>21</b>                                                                         | 888888      | charlie     |
| <b>22</b>                                                                         | princess    | aa123456    |
| <b>23</b>                                                                         | dragon      | donald      |
| <b>24</b>                                                                         | password1   | password1   |
| <b>25</b>                                                                         | 123qwe      | qwerty123   |

Y esto no cambia, comparen las mismas passwords a lo largo de los años, se darán cuenta que todo sigue prácticamente igual.

Vamos a revisar algunos de los tipos de ataques más comunes y algunas de las medidas para mitigarlos:

**ATAQUE DE DICCIONARIO:** Se utilizan programas para generar combinaciones de letras a partir de un número determinado de letras, caracteres, números y símbolos especiales.

**TASA DE ÉXITO:** BUENA (dado que muchos ponen palabras conocidas...)

```
[*] - Probando -> 59e902a0c5a900aef116e34ba730f6aae37fd30 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: warsaw
[*] - Probando -> c41aefb8a01d2303f0a5fd662d7aaef219479b99 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: wannabe
[*] - Probando -> 6ac9bf43972dc838e52c86288c24c360bc3b7448 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: walking
[*] - Probando -> 500476ae43a1856ae49c1660b6169c510646b435 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: videol
[*] - Probando -> f8c34104fde05e9ebdc5bb684f8911ebc9ae6217 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: vfkbyf
[*] - Probando -> 137b67b002be764428a38ab6d37b445cc22901d6 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: vasily
[*] - Probando -> 2ff6cd55f57ef2562705adef93a9e23dd24f1135 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: vangogh
[*] - Probando -> 252219fe3aeb0c703d35e0f87e8bc9824f43fca7 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: urlaub
[*] - Probando -> fa4082ed73612815a28f1057bf6b3f42d82d7c90 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: twostep
[*] - Probando -> bab5ff1c4e5bedd3e0c4951f67621d33635fffb8e ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: turk182
[*] - Probando -> 4c07f24e8dcff059e6ed1d5918db19ebe5bel19c ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: tryagain
[*] - Probando -> 0238fe4277c5f0ad2c558ff595c4aee6385417 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: trekker
[*] - Probando -> 91e9cc4e769bbc15114a2dbb813c6d53806afbd1 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: tramp
[*] - Probando -> 36e004e731a1110c5f9a862439b5e758d87fa4f6 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: toonces
[*] - Probando -> e71b0bad228ce8821f7ee3093146b594355fb11d ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: tomboy
[*] - Probando -> 90fa18f75036f7a6833022ab246c6ee47000912f ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: tom123
[*] - Probando -> 7c02734f2974bbefc56ad1f98525334c0ccaa4a ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: theshit
[*] - Probando -> 478efb0c123bc80bb097a29895496e11498d3af ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: theclash
[*] - Probando -> d2870e4d5556a8bc45af7652fac80fdbebda8ab2 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: terri
[*] - Probando -> 2337e66cf58161cc602862bffa420bdf4add4ea ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: terrence
[*] - Probando -> 178dc8a9d4cb37a5f1b26a29cc3cb8db31279c42 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: terrance
[*] - Probando -> 78a90d8e867452becc70ef338a64e30edb8954e7 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: taytay
[*] - Probando -> 551a1295556c210fee83aa71da02d8821850e8b1 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: system1
[*] - Probando -> 2e6246104abda7ae62e4cf5f0b0f591fc1ef6fdc ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: sunbeam
[*] - Probando -> 21e978895190671f4621765d561dc9f14ca71abc ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: streak
[*] - Probando -> 9fc09c92f9d4898dd6e5af3e81679b627e939258 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: steiner
[*] - Probando -> 910d5b538fd20e0789761ba8612c388926f390c9 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: stefania
[*] - Probando -> 35951e2654371df7c68de546b20b3c3794b62aae ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: stefani
[*] - Probando -> 78b0c6bc4729e97f8f527cb67d595b0d976c9617 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: soviet
[*] - Probando -> 63281cf8aad0992f3770ee72ef2814ce6e20c1b9 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: southside
[*] - Probando -> 8696760a4e53c107336b4022dc26ae0d27e649e6 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: sonny1
[*] - Probando -> c5b66b4906d5cb6dfbac3af86fc3319d7f4102f8 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: solnishko
[*] - Probando -> eb74f2cb1a9d6a502e420f61c204e2c2cb3c8a8 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: soft
[*] - Probando -> cc6262ba0d14893632ad4e1fa858efb6eda90b82 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: smokedog
[*] - Probando -> 27aced306f42ceebd872ccf84f345b4ad1b6c95c ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: smarty
[*] - Probando -> cce1eae8594a1fd3c187642b25cc6d81ee0e83bf ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: slayers
[*] - Probando -> 37423f3bd00f9eadfb351ceb16af47fbd0c988e1 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: skins
[*] - Probando -> bec782e3e2aef749748ddfeab8fb4d444d8de90 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: sk8ordie
[*] - Probando -> 502b7dfff6fb4dc619b4933e1cb122df34605430 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: singh
[*] - Probando -> e35b78f98a7d5e97029a32c16b016a7dbc23ab86 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: sienna
[*] - Probando -> df0eae1075d0d5f3db41d6ef639093f37a5a6258 ?= df0eae1075d0d5f3db41d6ef639093f37a5a6258: DtxdF123
[*] - Crackead -> DtxdF123 = df0eae1075d0d5f3db41d6ef639093f37a5a6258
```

Estos tipos de diccionarios se pueden crear, por ejemplo con el programa CRUNCH” o existen en la web, cientos de diccionarios ya creados, que lo único que hay que realizar, es bajarlos y utilizarlos en la herramienta indicada para realizar las pruebas de autenticación (HYDRA, BRUTUS, ETC).

**ATAQUE DE FUERZA BRUTA:** Se basa en intentar obtener el password, probando todas las posibles combinaciones de palabras, que se puedan combinar utilizando un diccionario de palabras y un generador de combinaciones de letras.

De acuerdo a la cantidad de palabras y la potencia del sistema utilizado para generar las combinaciones, dependerá la probabilidad de éxito de este ataque.

Se puede configurar un software (de ataque) para iniciar con una combinación de una palabra y 3 letras, cambiando la combinación con todos los caracteres, y símbolos disponibles.

A medida que aumenta la complejidad, aumenta exponencialmente los requerimientos de procesamiento y cálculo.

TASA DE ÉXITO: MUY BUENA. (La gran contra que tiene, es uno de los factores más importantes para un atacante: TIEMPO vs LONGITUD)

```
sshd[20210]: Failed password for root from 219.33.1
sshd[18872]: Failed password for root from 219.33.1
sshd[17305]: Failed password for root from 219.33.1
sshd[6064]: Received disconnect from 219.33.1: 1:
sshd[19041]: Received disconnect from 219.33.1: 1:
sshd[3521]: Received disconnect from 219.33.1: 1:
sshd[8710]: Failed password for root from 219.33.1
sshd[31665]: Received disconnect from 219.33.1: 1:
sshd[22899]: Failed password for root from 219.33.1
sshd[8828]: Failed password for root from 219.33.1
sshd[19068]: Failed password for root from 219.33.1
sshd[10990]: Received disconnect from 219.33.1: 1:
sshd[8615]: Received disconnect from 219.33.1: 1:
sshd[11402]: Received disconnect from 219.33.1: 1:
```

No es lo mismo “123a456s” que “Jh6r+Plnb73\_kle” Link a una calculadora de BruteForcePassword <https://www.grc.com/haystack.htm>

GRC's Interactive Brute Force Password "Search Space" Calculator  
(NOTHING you do here ever leaves your browser. What happens here, stays here.)

☒ 4 Uppercase   ☒ 4 Lowercase   ☒ 5 Digits   ☒ 1 Symbol  

**L1p?23RnS98Tra**

Enter and edit your test passwords in the field above while viewing the analysis below.

**Brute Force Search Space Analysis:**

|                                                                                                                                |                                       |
|--------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| Search Space Depth (Alphabet):                                                                                                 | 26+26+10+33 = <b>95</b>               |
| Search Space Length (Characters):                                                                                              | <b>14</b> characters                  |
| Exact Search Space Size (Count):<br>(count of all possible passwords with this alphabet size and up to this password's length) | 4,928,630,108,082,482,617,642,017,120 |
| Search Space Size (as a power of 10):                                                                                          | 4.93 x 10 <sup>27</sup>               |

**Time Required to Exhaustively Search this Password's Space:**

|                                                                                        |                                  |
|----------------------------------------------------------------------------------------|----------------------------------|
| Online Attack Scenario:<br>(Assuming one thousand guesses per second)                  | 1.57 thousand trillion centuries |
| Offline Fast Attack Scenario:<br>(Assuming one hundred billion guesses per second)     | 15.67 million centuries          |
| Massive Cracking Array Scenario:<br>(Assuming one hundred trillion guesses per second) | 15.67 thousand centuries         |

Note that typical attacks will be online password guessing limited to, at most, a few hundred guesses per second.

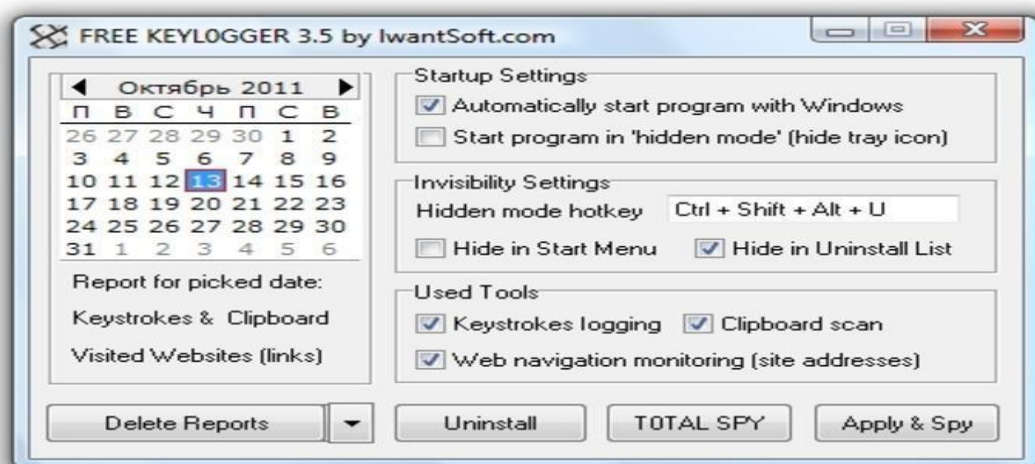
Hagan pruebas para que noten la diferencia entre 4 palabras simples concatenadas (nueva + clave) y el uso de caracteres especiales. Por ejemplo, probar las siguientes claves:

“nuevaclave” / “nu3v@claVe” / “NueVaCLaVe” / “nUEvAclAvE”

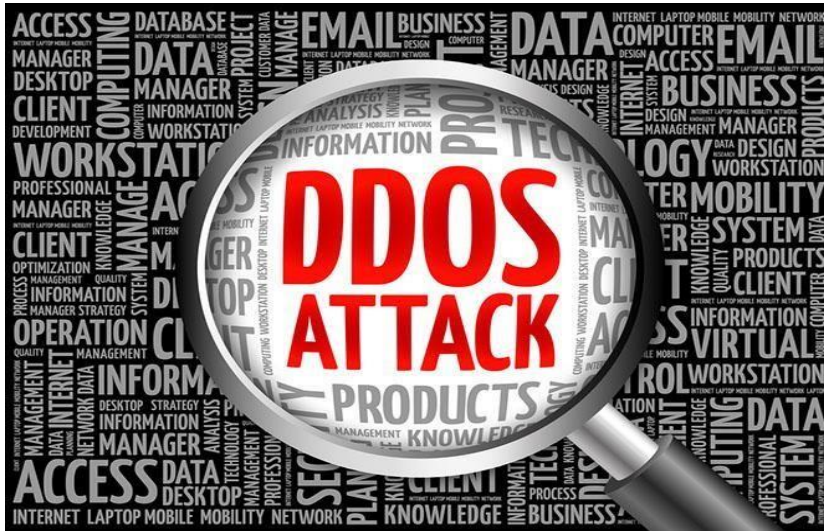
Pantallas de login falsas: se presenta al usuario una copia falsa de la pantalla de login, cuando el usuario ingresa las credenciales estas se envían al atacante, en algunos casos se cierra la pantalla falsa y se carga automáticamente la pantalla verdadera, para enmascarar el ataque.



Key Logger attack: el atacante utiliza un programa malicioso para obtener un registro de todas las pulsaciones de teclas en el sistema objetivo. De esta forma puede obtener las credenciales necesarias para acceder al objetivo. Existen keyloggers del tipo software y hardware, estos últimos se instalan como una interfaz física entre el teclado y la CPU.



## Denegación de servicio (DOS)

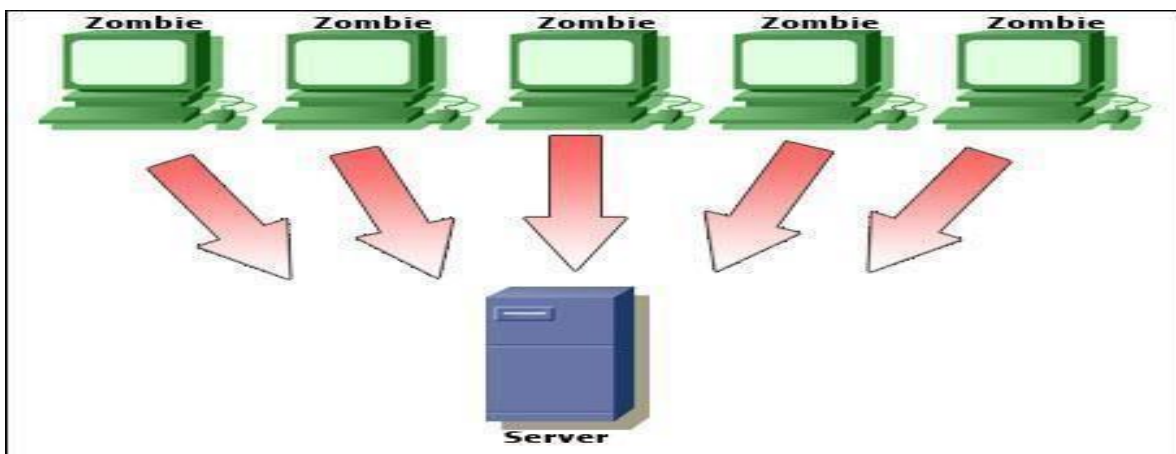


Sus funciones pueden ser anular, impropiar, impedir, destruir, a la comunicación o información activa a través de sistemas o servicios, afectando uno de los pilares de la información, la disponibilidad.

La manera de realizar esta técnica suele ser aprovechando vulnerabilidades, saturar un enlace o inutilizar servicios.

A través de programas, o con peticiones HTTP, y hasta del famoso comando “PING”.

Por eso es tan importante saber cómo mitigar esto.



Hay muchas maneras de llevarlo a cabo, por ejemplo, a través de una o varias botnets (red de máquinas comprometidas), todas trabajando en conjunto, realizando operaciones, como “impedir el acceso al servidor”.

## ¿Qué es un ataque DoS/DDoS?

Un ataque DoS/DDoS tiene como objetivo inhabilitar el target seleccionado mediante la saturación de la conexión. Esto se realiza de muchas maneras, la más común es el FLOODING (inundación de paquetes) hacia un puerto abierto específico donde esté corriendo una aplicación.

## Diferencias entre ataques DoS/DDoS

La diferencia entre estos dos ataques es la cantidad de máquinas utilizadas para realizar el ataque, en DoS utilizamos una máquina, en DDoS utilizamos varios servidores que redirigen sus ataques a un mismo sitio con el fin de dejarlo incomunicado lo más rápido posible.

## ¿Cómo se componen estos ataques?

Los ataques, al tener que ser dirigidos a un target, necesitan tener la IP (y en algunas ocasiones el puerto) del servicio que quieren inhabilitar.

Los atacantes DDoS apuntarán a cualquier punto potencial de falla, como:

Servidores del Sistema de nombres de dominio (DNS): la infraestructura de DNS es un objetivo maduro para los actores maliciosos, ya que proporciona un servicio necesario para que los navegadores de los usuarios finales puedan buscar su dirección IP y encontrar su sitio web. Obtenga más información sobre los ataques de DNS.

Servidor de origen: los servidores que alojan sus sitios web, aplicaciones web y contenido web son destinos. Los atacantes pueden omitir sus otras protecciones si pueden acceder directamente a su servidor de origen, que puede estar en la nube o en un centro de datos.

Sitio web: incluso un simple ataque DDoS puede inundar un sitio web desprotegido con un alto volumen de solicitudes que excede su capacidad.

Aplicación web: una aplicación web no puede distinguir fácilmente la diferencia entre un ataque DDoS y las solicitudes legítimas de los usuarios. Las páginas de inicio de sesión suelen estar dirigidas, porque activan procesos de back-end que consumen ciclos de CPU en el servidor web, como la prevención de fraudes, el acceso a bases de datos y las rutinas de autenticación.

Interfaces de programación de aplicaciones (API): las API se dirigen con mayor frecuencia, en parte porque cada vez más sitios web habilitan las comunicaciones a través de las API. Las API pueden enviar información a las aplicaciones móviles o extraer contenido de fuentes de contenido de terceros en una aplicación web.

Centro de datos e infraestructura de red: los objetivos son la infraestructura de red y centro de datos y el ancho de banda de la red en un centro de datos. Si un atacante puede llenar los conductos de su red o abrumar a los enrutadores y conmutadores, el tráfico legítimo no puede pasar.

**ANTE TODO, RECORDAR:** este tipo de ataque, está contemplado dentro de la ley de delitos informáticos Número 26388, así que tener en cuenta que la realización del mismo, sin ninguna autorización, se encuentra penada por la ley.

### Ataques de modificación

Suelen ser los que modifican datos, servicios, funciones administrativas, para poder realizar actos maliciosos o asegurarse ingresos futuros.

Muy utilizado para modificar sitios webs (defacements), ingresando código malicioso como también es usado para desactivar medidas de seguridad (antivirus, reglas de acceso, etc.).

Suelen realizarse a través de vulnerabilidades, programación, ejecución maliciosa, y por intermedio de emails (phishing).



Alguno de los "defacements" pueden contener mensajes políticos, religiosos e injuriosos, así como muchas veces los servidores comprometidos son utilizados como plataformas de distribución de malware, para poder expandir el control de lo obtenido.



Muy utilizado para modificar a través de un acceso no autorizado, cambiar información específica, por ejemplo, tráfico hacia bases de datos, mensajes en una red, etc.

Un sitio que nos mantiene al tanto de los últimos ataques utilizando esta técnica.

<http://www.zone-h.org>

| Date       | Notifier            | H | M | R | L   | ★ Domain                          | OS       | View                   |
|------------|---------------------|---|---|---|-----|-----------------------------------|----------|------------------------|
| 2020/12/19 | FRK48               |   |   |   |     | www.eaaargentina.org/0x48.htm     | Linux    | <a href="#">mirror</a> |
| 2020/12/19 | FRK48               |   |   |   | M   | eglobal-argentina.com.ar/0x48.htm | Win 2016 | <a href="#">mirror</a> |
| 2020/10/22 | UMCA                |   |   |   |     | www.miargentina.us/license.txt    | Linux    | <a href="#">mirror</a> |
| 2020/10/09 | UMCA                |   |   |   |     | www.sitargentina.com.ar/eagle.txt | Linux    | <a href="#">mirror</a> |
| 2020/09/12 | S A T A N           |   |   |   | M   | www.vivotek-argentina.com.ar/k... | Linux    | <a href="#">mirror</a> |
| 2020/09/12 | S A T A N           |   |   |   |     | todocannabisargentina.com/kill... | Linux    | <a href="#">mirror</a> |
| 2020/09/10 | KatiB               |   |   |   | M   | sabinaenargentina.com/index.html  | Linux    | <a href="#">mirror</a> |
| 2020/09/10 | KatiB               |   |   |   | M   | www.sabinaserratenargentina.co... | Linux    | <a href="#">mirror</a> |
| 2020/09/01 | TheWayEnd           |   |   |   | M   | claudiaotsuboescritoraargentin... | Win 2016 | <a href="#">mirror</a> |
| 2020/08/13 | Malware Dot ID      |   |   |   |     | www.aviacionargentina.net/foro... | Linux    | <a href="#">mirror</a> |
| 2020/07/27 | Royal Battler BD    |   |   |   |     | www.parentesisargentina.com/Fi... | Linux    | <a href="#">mirror</a> |
| 2020/06/08 | KrdSec              |   |   |   | M   | biocorargentina.com.ar/ks.html    | Win 2012 | <a href="#">mirror</a> |
| 2020/06/08 | KrdSec              |   |   |   | M   | exus-argentina.com/ks.html        | Win 2012 | <a href="#">mirror</a> |
| 2020/06/08 | KrdSec              |   |   |   | M   | simsaargentina.com.ar/ks.html     | Win 2012 | <a href="#">mirror</a> |
| 2020/06/05 | ./cOLI              |   |   |   | R   | www.okidoargentina.com/love.htm   | Linux    | <a href="#">mirror</a> |
| 2020/05/18 | MISH                |   |   |   |     | visit-argentina.co.uk/si.htm      | Linux    | <a href="#">mirror</a> |
| 2020/04/24 | Xsam Xadoo Bot      |   |   |   |     | wepargentina.com/Xsam_Xadoo.html  | Linux    | <a href="#">mirror</a> |
| 2020/04/17 | theMxOnday          |   |   |   |     | www.difilm-argentina.com          | Linux    | <a href="#">mirror</a> |
| 2020/03/30 | org0n               |   |   |   | H M | moringa-argentina.com.ar          | Linux    | <a href="#">mirror</a> |
| 2020/03/28 | [Nyu]               |   |   |   | H M | pallmannargentina.com             | Unknown  | <a href="#">mirror</a> |
| 2020/03/28 | Ferdysimo           |   |   |   | H M | www.carhouseargentina.com         | Unknown  | <a href="#">mirror</a> |
| 2020/03/26 | [Nyu]               |   |   |   | H M | www.kala-argentina.com            | Unknown  | <a href="#">mirror</a> |
| 2020/03/20 | Moroccan Revolution |   |   |   |     | lifeargentina.org/ma.htm          | Linux    | <a href="#">mirror</a> |
| 2020/03/19 | L4NC34              |   |   |   | M R | www.ofenbauargentina.com.ar/se... | Linux    | <a href="#">mirror</a> |
| 2020/03/19 | The3x               |   |   |   | R   | www.registrarargentina.com.ar/... | Unknown  | <a href="#">mirror</a> |

Donde se puede buscar por país como en este caso.

Cientos de sitios, que fueron modificados, en la opción VIEW, exponen que fue lo que realizaron en la estructura del mismo.

## Escaneo de Vulnerabilidades



Hablamos mucho de las vulnerabilidades, ¿pero qué son?

Según WIKI: Las vulnerabilidades son puntos débiles del software que permiten que un atacante comprometa la integridad, disponibilidad o confidencialidad del mismo.



Varios de los vendors más conocidos

Según experiencia: son los agujeros o errores que dejamos o dejaron “inconscientemente” en servicios o procedimientos, por no tener información adecuada y concisa para usar las medidas de seguridad necesarias impidiendo esto...



Pero no siempre es así, un Scanner de vulnerabilidades, no detectaría este tipo de vulnerabilidad expuesta.

Volviendo a los parámetros de servicios. Existen sitios en donde uno puede encontrar diferentes tipos de vulnerabilidades, de acuerdo al tipo de proceso, sistema o tecnología utilizado.

## Local & Privilege Escalation Exploits

This exploit category includes local exploits or privilege escalation exploits.

| Date Added | D | A | V | Title                                                                         | Platform | Author     |
|------------|---|---|---|-------------------------------------------------------------------------------|----------|------------|
| 2018-01-11 |   | - |   | Parity Browser < 1.6.10 - Bypass Same Origin Policy                           | Multiple | tintinweb  |
| 2018-01-10 |   | - |   | Jungo Windriver 12.5.1 - Local Privilege Escalation                           | Windows  | Fidus...   |
| 2018-01-08 |   | - |   | Microsoft Windows - Local XPS Print Spooler Sandbox Escape                    | Windows  | Google...  |
| 2018-01-05 |   | - |   | VMware Workstation - ALSA Config File Local Privilege Escalation (Metasploit) | Linux    | Metasploit |
| 2018-01-04 |   | - |   | Multiple CPUs - 'Spectre' Information Disclosure                              | Multiple | Multiple   |
| 2018-01-03 |   | - |   | Kingsoft Antivirus/Internet Security 9+ - Privilege Escalation                | Windows  | mr_me      |
| 2017-12-27 |   | - |   | Sony Playstation 4 4.05 FW - Local Kernel Loader                              | BSD      | Specter    |

Por suerte, esta técnica también es utilizada por los profesionales del área, para detectar esos “agujeros” y poder mitigarlos de la mejor manera posible.

El mismo escaneo (llámese “investigación”) se realiza de dos maneras: **modo manual** chequeando a fondo todo lo que se encuentra a través de servicios, sistemas, etc. buscando esos errores o puertas traseras (Backdoors), o **modo automático** gracias a programas y/o aplicaciones que nos mostrarán (o no) la vulnerabilidad detectada y su posible solución.